



Logon

logon 



Easy

Web Exploitation

picoCTF 2019

AUTHOR: BOBSON

Description

The factory is hiding things from all of its users.
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.
Its current status is:

NOT_RUNNING

Launch Instance

Hints

1

Hmm it doesn't seem to check anyone's password, except for Joe's?

88,425 users solved



93%

Liked



 picoCTF{FLAG}

Submit
Flag

Author: The Analyst: Hyposelenia

Challenge: Logon

Category: Web Exploitation

Date: 02/15/26



I. Objective

The objective of this challenge is to bypass a weak authentication system by analyzing client-side cookies and modifying an insecure Boolean value to gain administrator access and retrieve the hidden flag.

II. Background

Web applications often use **cookies** to store session-related data such as login status, user roles, or preferences. Cookies are stored on the **client side** (the user's browser) and are sent to the server with each request.

If a web application **trusts cookies without validating them on the server**, attackers can manipulate these values to gain unauthorized access. This challenge demonstrates a common security flaw where **authorization is controlled by a client-side Boolean value**, making it vulnerable to tampering.

III. Tool Used

- **Web Browser** – Used to access the website
- **Browser Developer Tools (Inspect)** – Used to view and modify cookies

IV. Methodology

1. Launched the challenge instance.

NOT_RUNNING

Launch Instance



2. Accessed the provided URL using a web browser.

Factory Login [Home](#) [Sign Out](#)

[Sign In](#)

© PicoCTF 2019

3. Attempted to log in using random usernames and passwords.

Factory Login [Home](#) [Sign Out](#)

[Sign In](#)

© PicoCTF 2019

4. Observed that the site allowed login without properly validating credentials.

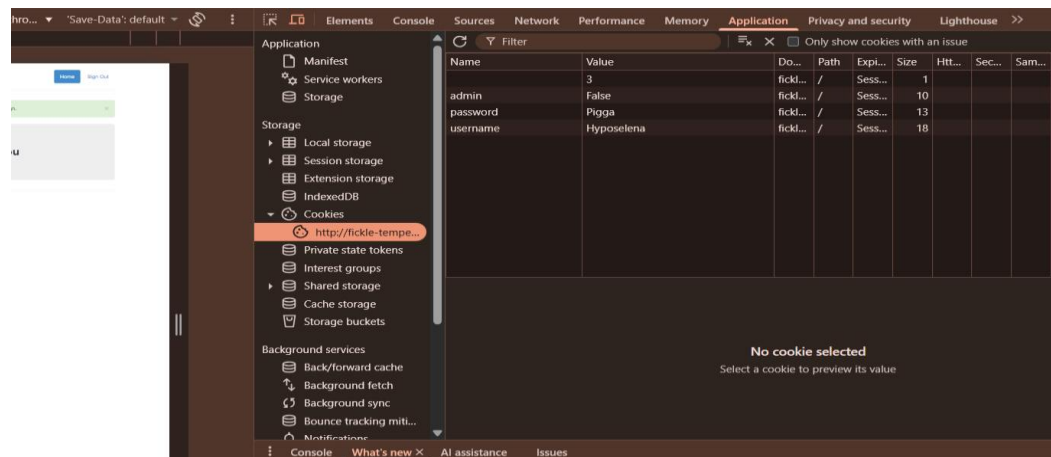
Factory Login [Home](#) [Sign Out](#)

Success: You logged in! Not sure you'll be able to see the flag though. [✕](#)

No flag for you

© PicoCTF 2019

5. Right-clicked on the page and opened **Inspect (Developer Tools)**.
6. Navigated to the **Application** tab, then to **Cookies**.



7. Found a cookie labeled admin with the value set to false.
8. Manually changed the cookie value from false to true.
9. Refreshed the page.
10. Gained administrator access and retrieved the flag.

V. Result

picoCTF{th3_c0nsp1r4cy_l1v3s_4d184b0d}

VI. Explanation

Imagine a website is like a school.

- A **cookie** is like a **note or tag** the teacher puts in your backpack.

The note says:

- “Is this student an admin?”
- The note says **NO**.

But instead of the teacher checking their own records, the teacher just **reads the note in your bag**.

You open your bag, change the note from **NO** to **YES**, and suddenly the teacher thinks you are the principal. That’s exactly what happened in this challenge.



Have you ever asked why it logs you in? The challenge hint says:

“It doesn’t check anyone’s password, except for Joe’s.”

This means:

- The website **does not properly validate login credentials**
- Any username/password combination logs you in
- Authentication is weak or incomplete

The real protection was not the password — it was the **admin cookie**!

So why did we bother changing the admin’s value? Simple!

The website uses a **Boolean value**:

- admin = false → regular user
- admin = true → administrator

This value is:

- Stored in a **client-side cookie**
- Fully editable by the user
- **Not verified by the server**

Because the server blindly trusts this cookie, changing it grants admin privileges instantly.

This challenge teaches three critical cybersecurity lessons:

1. **Client-side data cannot be trusted**
2. **Authorization must be enforced server-side**
3. **Cookies should never control access levels directly**

It demonstrates a real-world vulnerability known as:

Broken Access Control

This is one of the **Top 10 Web Vulnerabilities**.



VII. Conclusion

The Logon challenge highlights the dangers of trusting client-side cookies for authentication and authorization. By exploiting a Boolean admin flag stored in the browser, unauthorized administrative access was achieved without cracking any passwords. This reinforces the importance of server-side validation, secure session handling, and proper access control in web application security. The challenge effectively demonstrates how small implementation mistakes can lead to major security breaches.

— **The Analyst: Hyposelenia**